TECHNICAL DETAIL

Title	Information Disclosure via Debug Mode (Laravel Ignition) on Employee Update Feature
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://pegawai.my.id/employees/{id}
Severity	**Low**
CVSS Score	2.7 (CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:N/A:N)
Proof of Concepts	Please see Steps to Reproduce section

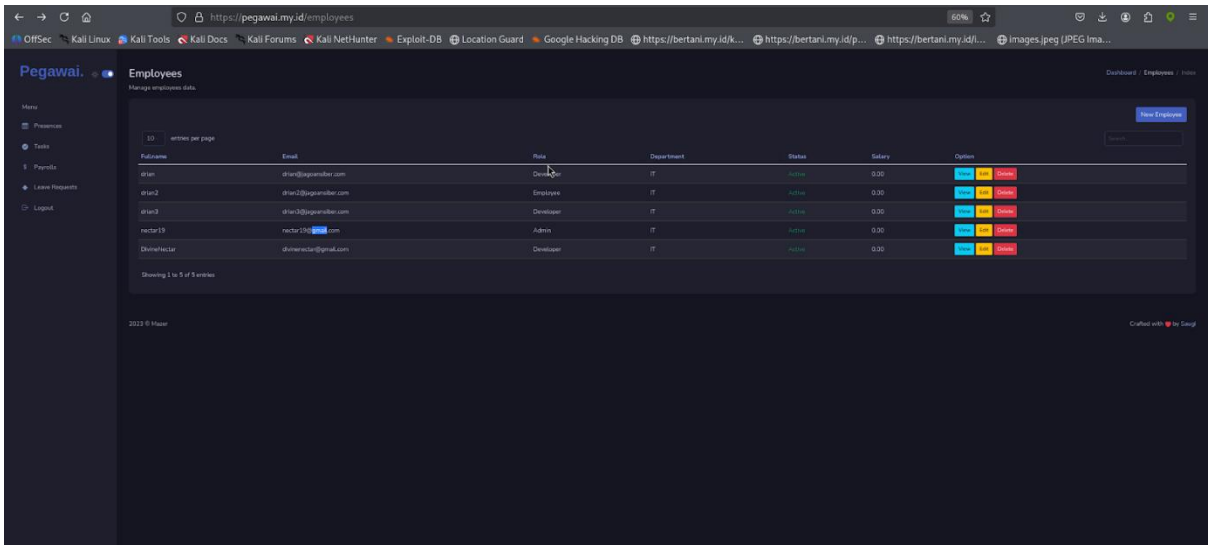
SUMMARY

Ditemukan kesalahan konfigurasi pada server produksi pegawai.my.id di mana mode debug (APP_DEBUG=true) aktif. Akibatnya, saat terjadi kesalahan sistem atau database (seperti pengisian data yang tidak lengkap), aplikasi menampilkan halaman debugging Laravel Ignition yang berisi rincian teknis internal aplikasi alih-alih menampilkan halaman error generik.

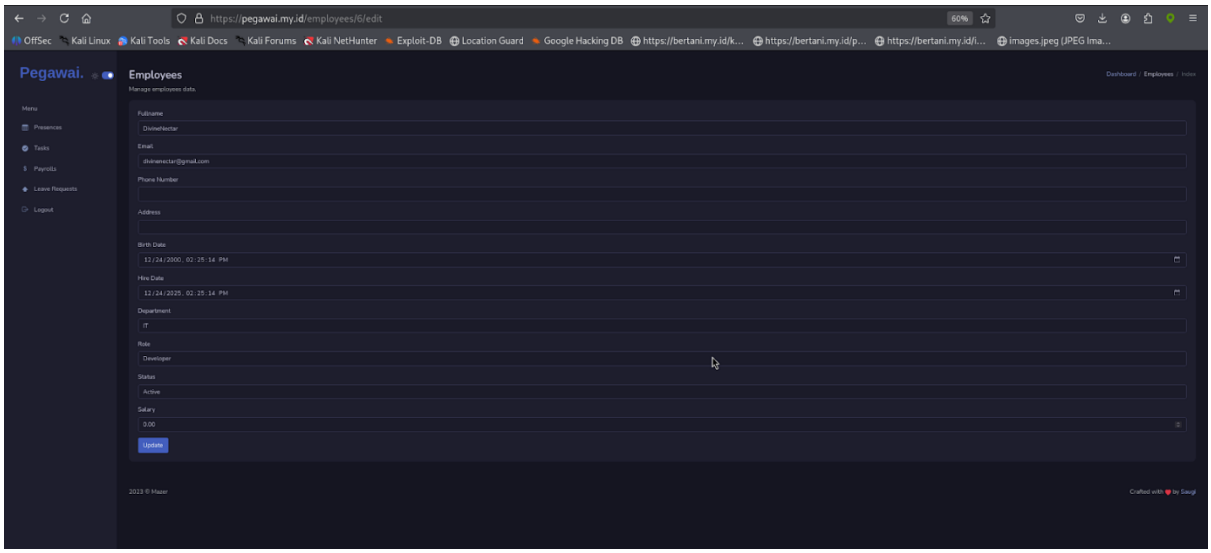
STEPS TO REPRODUCE

1. Login ke Akun Anda sebagai user di URL https://pegawai.my.id/login

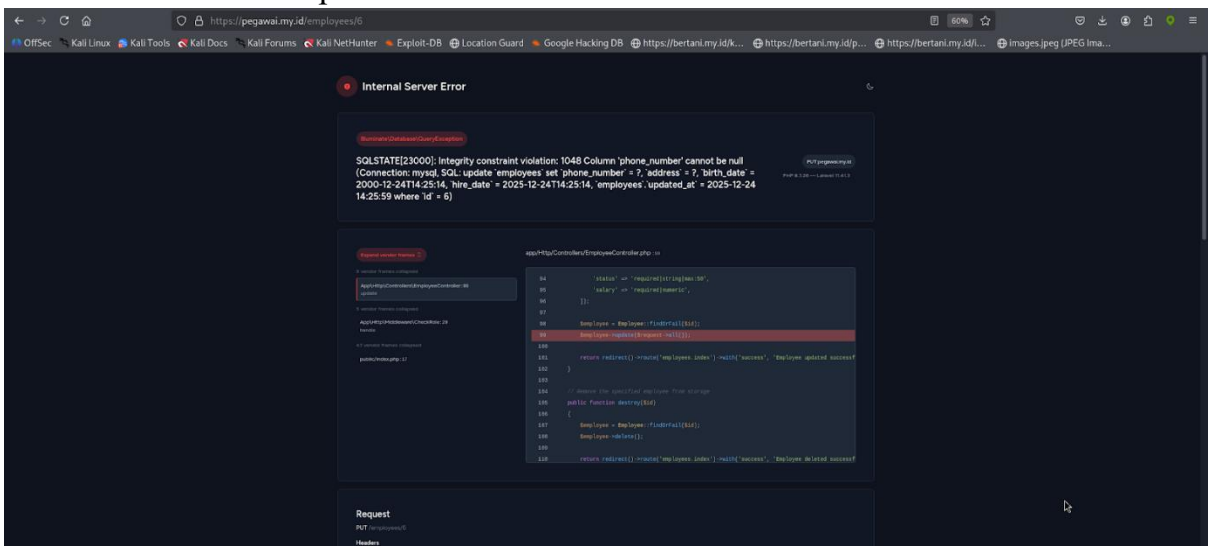
2. Masuk ke url https://bertani.my.id/employees dan klik edit



3. Lalu isi tapi jangan lengkap disini saya kosongkan phone number dan address lalu klik update



4. Lalu web akan menampilkan informasi



EXPECTED RESULT

Server pada lingkungan produksi seharusnya dikonfigurasi untuk menyembunyikan detail teknis dari pengguna. Pesan kesalahan yang ditampilkan seharusnya bersifat umum (contoh: "500 Internal Server Error") untuk mencegah kebocoran informasi.

ACTUAL RESULT

Sistem menampilkan halaman kesalahan spesifik SQLSTATE[23000]: Integrity constraint violation yang membocorkan:

1. Struktur perintah SQL update yang digunakan oleh aplikasi.
2. Jalur direktori file internal di server
3. Daftar *query* database yang dieksekusi selama sesi tersebut.

IMPACT

1. Information Disclosure (Low): Memberikan informasi teknis berharga bagi penyerang untuk memahami struktur internal aplikasi dan basis data (tahap *reconnaissance*).
2. Eksposur Logika Bisnis: Penyerang dapat melihat bagaimana data divalidasi dan diproses, yang dapat digunakan untuk merancang serangan yang lebih terarah di masa depan

RECOMMENDATION

1. Nonaktifkan Mode Debug: Ubah pengaturan pada file .env menjadi APP_DEBUG=false untuk lingkungan produksi.
2. Validasi Input: Terapkan validasi data yang ketat di sisi server untuk memastikan semua kolom wajib terisi sebelum berinteraksi dengan basis data.
3. Gunakan Error Logging: Alihkan detail kesalahan teknis ke file log internal server dan tampilkan halaman 500 yang aman bagi pengguna publik.

REFERENCES

1. OWASP Top 10 - A05:2021 Security Misconfiguration: https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
2. CWE-200: Exposure of Sensitive Information to an Unauthorized Actor: https://cwe.mitre.org/data/definitions/200.html
3. Laravel Documentation - Error Handling: https://laravel.com/docs/10.x/errors